

ANALISIS RISIKO (THREAT MODELING)

1.1 Identifikasi Ancaman Keamanan

Dalam pengembangan aplikasi berbasis web, keamanan sistem merupakan aspek penting yang harus diperhatikan sejak tahap perancangan. Sistem yang terhubung dengan jaringan internet memiliki potensi terhadap berbagai jenis serangan yang dapat mengancam kerahasiaan, integritas, dan ketersediaan data.

Pada sistem Jatibahagya WebApp, terdapat beberapa komponen yang berpotensi menjadi target serangan, seperti fitur autentikasi login, pengelolaan data pengguna, serta fitur komunikasi chat antara pengguna dan admin. Oleh karena itu diperlukan proses threat modeling untuk mengidentifikasi kemungkinan ancaman keamanan yang dapat terjadi.

Beberapa ancaman keamanan yang berpotensi terjadi pada sistem ini antara lain Brute-force Attack, SQL Injection, Session Hijacking, dan Cross-Site Scripting (XSS).

1.2 Brute-force Attack

1. Deskripsi Ancaman

Brute-force attack merupakan teknik serangan yang dilakukan dengan mencoba berbagai kombinasi username dan password secara berulang hingga berhasil mendapatkan kredensial yang valid. Serangan ini biasanya menargetkan sistem autentikasi login.

Pada sistem Jatibahagya WebApp, fitur login dapat menjadi target brute-force attack apabila tidak dilengkapi dengan mekanisme perlindungan yang memadai.

2. Dampak Serangan

Jika serangan brute-force berhasil dilakukan, maka penyerang dapat memperoleh akses tidak sah ke akun pengguna atau administrator. Hal ini dapat mengakibatkan pencurian data, manipulasi informasi produk, maupun penyalahgunaan akun.

3. Mitigasi

Untuk mengurangi risiko brute-force attack, sistem menerapkan beberapa mekanisme pengamanan, antara lain:

- Enkripsi password menggunakan algoritma hashing sehingga password tidak disimpan dalam bentuk plaintext di database.
- Pembatasan jumlah percobaan login (login attempt limit) untuk mencegah percobaan login berulang dalam waktu singkat.
- Penggunaan CAPTCHA pada proses login setelah beberapa kali percobaan gagal.
- Penerapan HTTPS untuk melindungi transmisi data login dari penyadapan.

1.3 SQL Injection

1. Deskripsi Ancaman

SQL Injection merupakan teknik serangan yang memanfaatkan celah keamanan pada input pengguna untuk menyisipkan perintah SQL berbahaya ke dalam query database. Serangan ini dapat terjadi apabila sistem tidak melakukan validasi atau sanitasi input dengan benar.

Dalam sistem Jatibahagya WebApp, potensi SQL Injection dapat terjadi pada fitur login, pencarian produk, maupun pengelolaan data oleh admin.

2. Dampak Serangan

Serangan SQL Injection dapat memungkinkan penyerang untuk:

- Mengakses data sensitif dari database
- Mengubah atau menghapus data
- Melewati proses autentikasi login

Hal ini dapat menyebabkan kebocoran data pengguna maupun kerusakan data sistem.

3. Mitigasi

Beberapa langkah mitigasi yang diterapkan dalam sistem antara lain:

- Menggunakan prepared statement atau parameterized query untuk mencegah injeksi perintah SQL.
- Melakukan validasi dan sanitasi input pengguna sebelum diproses oleh sistem.
- Membatasi hak akses database berdasarkan prinsip least privilege.
- Melakukan filter karakter khusus yang berpotensi digunakan dalam injeksi SQL.

1.4 Session Hijacking

1. Deskripsi Ancaman

Session hijacking merupakan serangan yang dilakukan dengan mengambil alih session pengguna yang sedang aktif. Penyerang dapat memperoleh session ID melalui berbagai cara, seperti penyadapan jaringan atau eksploitasi celah keamanan pada aplikasi web.

Jika session pengguna berhasil dicuri, penyerang dapat bertindak seolah-olah sebagai pengguna yang sah tanpa perlu mengetahui username dan password.

2. Dampak Serangan

Dampak dari session hijacking antara lain:

- Akses tidak sah ke akun pengguna
- Penyalahgunaan fitur sistem
- Pengubahan atau penghapusan data penting

3. Mitigasi

Untuk mengurangi risiko session hijacking, sistem menerapkan beberapa mekanisme pengamanan, yaitu:

- Menggunakan HTTPS untuk mengenkripsi komunikasi antara client dan server.
- Menggunakan session ID yang bersifat acak dan sulit ditebak.
- Menerapkan session timeout sehingga session akan otomatis berakhir setelah periode tidak aktif.
- Menggunakan atribut keamanan pada cookie seperti HttpOnly dan Secure.

1.5 Cross-Site Scripting (XSS)

1. Deskripsi Ancaman

Cross-Site Scripting (XSS) merupakan serangan yang memungkinkan penyerang menyisipkan script berbahaya ke dalam halaman web yang kemudian dijalankan di browser pengguna lain. Serangan ini biasanya terjadi pada aplikasi yang menerima input dari pengguna tanpa melakukan validasi atau penyaringan yang memadai.

Pada sistem Jatibahagya WebApp, potensi serangan XSS dapat terjadi pada fitur chat atau form input lainnya seperti pencarian produk.

2. Dampak Serangan

Jika serangan XSS berhasil dilakukan, maka penyerang dapat:

- Mencuri cookie atau session pengguna
- Mengalihkan pengguna ke situs berbahaya
- Menjalankan script berbahaya pada browser pengguna

3. Mitigasi

Untuk mencegah serangan XSS, sistem menerapkan beberapa langkah pengamanan, yaitu:

- Melakukan validasi dan sanitasi input pengguna sebelum ditampilkan kembali pada halaman web.
- Menggunakan escaping karakter HTML untuk mencegah eksekusi script.
- Menerapkan Content Security Policy (CSP) untuk membatasi sumber script yang dapat dijalankan pada halaman web.
- Menghindari penggunaan fungsi yang dapat mengeksekusi kode secara langsung dari input pengguna.

1.6 Ringkasan Mitigasi Ancaman

Secara keseluruhan, sistem Jatibahagya WebApp dirancang dengan mempertimbangkan berbagai potensi ancaman keamanan yang umum terjadi pada aplikasi web. Dengan menerapkan mekanisme pengamanan seperti enkripsi data, validasi input, penggunaan HTTPS, serta pengelolaan session yang aman, sistem diharapkan mampu meminimalkan risiko serangan dan menjaga keamanan data pengguna.